

AI Trust Graph: A Graph-Driven, Evidence-Based Methodology for AI Assurance

Reasoning about trust, authority, paths, controls, evidence, and accountable decisions across connected AI systems

Siva Sethumadhavan

Whitepaper v1.0-rc.1 - Publication review candidate
October 2026

Methodology baseline: AI Trust Graph methodology bundle 1.0-rc.4, snapshot 26 September 2026
Manifest blob: 82c401ad27d31ddc0078e58dd99f38ac0b71a7d9

Publication status

This whitepaper is a non-normative narrative introduction to the AI Trust Graph methodology. The governed AI Trust Graph methodology artifacts maintained in the public repository remain the canonical source for definitions, controls, evidence grades, maturity rules, scoring rules, assessment procedures, reporting requirements, ontology, governance and conformance requirements. If explanatory language in this paper appears inconsistent with the canonical methodology, the governed canonical artifacts prevail.

This draft is frozen to AI Trust Graph methodology bundle 1.0-rc.4, snapshot 26 September 2026. The corresponding methodology manifest blob is 82c401ad27d31ddc0078e58dd99f38ac0b71a7d9. That pin is a reproducibility reference, not a validation claim.

At this baseline, AI Trust Graph is a public-release candidate. The methodology author's internal review is complete. The following external release gates remain pending until completed and recorded through governance: independent methodology or architecture review; independent AI-security review; an inter-assessor reproducibility study using the protocol in Artifact #10 Appendix B.4; employer, IP and confidentiality review; and legal approval of the licence and trademark position. Nothing in this paper should be interpreted as a claim that AI Trust Graph has been independently validated, academically peer reviewed, standardized, accredited, certified, or empirically proven to guarantee AI safety, security or compliance.

AI Trust Graph is a methodology, not a product. It is vendor-neutral and tool-independent. ExposureGraph product design, proprietary algorithms, connectors, customer data and commercial workflows are outside the public methodology and outside this whitepaper.

Abstract

AI systems increasingly operate as connected systems rather than isolated models. Models interact with identities, agents, tools, APIs, data stores, retrieval mechanisms, infrastructure, external providers, human decision-makers and business processes. In such environments, consequential risk may not reside within any single component. It can emerge through the relationships that connect them: who or what is trusted, what authority has been delegated, which actions are reachable, where boundaries are crossed, and whether effective controls interrupt a material path.

AI Trust Graph is an open, vendor-neutral and product-independent methodology for reasoning

about these conditions as a connected assurance problem. It represents an AI-enabled environment as a directed, labelled multigraph in which relevant assets and assessment objects are connected through explicit relationships involving trust, authority, access, invocation, dependency, data movement and control. The objective is not merely to inventory components, but to understand how relationships compose into consequential paths and how those paths are constrained, evidenced and governed.

The methodology organizes assessment across six domains: Discovery and AI Bill of Materials (AIBOM); Trust and Privilege Paths; Authority Governance; AI Security Validation; AI Governance and Assurance; and Operational Resilience. These domains are operationalized through seventy-two canonical controls and supported by a cumulative maturity model, an evidence-grading model, a controlled thirteen-phase assessment lifecycle, path-oriented analysis, reporting requirements and methodology governance.

A central principle is that evidence strength and control effectiveness are different questions. A claim that a control exists or operates effectively must be supported by evidence appropriate to that claim. Strong evidence may demonstrate that a control is ineffective, while weak evidence cannot justify a strong assurance conclusion merely because an expected control has been documented.

The methodology also preserves uncertainty explicitly. UNKNOWN represents a condition in which material evidence is absent, insufficient or materially conflicting. It is not equivalent to safety, failure, low risk, zero, Not Applicable or Not Tested. Unresolved uncertainty remains part of the assurance state rather than being silently converted into a favourable or adverse score.

AI Trust Graph does not produce a universal or overall trust score. Quantitative mechanisms are used only for defined purposes. The Path Exposure Index (PEI) supports prioritization of eligible, sufficiently determined active paths; it is not probability, expected loss, certification status or a substitute for professional judgment. Maturity is similarly determined through cumulative, evidence-gated requirements rather than by averaging control scores.

The resulting assurance model links system structure to accountable decision-making through a reasoning chain: Assets -> Relationships -> Authority -> Paths -> Controls -> Evidence -> Decisions. This paper explains that model, its six assessment domains, evidence and uncertainty discipline, lifecycle, scoring boundaries, governance and limitations, and demonstrates their interaction through a governed synthetic reference case.

1. The assurance problem

1.1 Connected AI changes the unit of analysis

An AI-enabled service is rarely just a model endpoint. In a production environment, it may depend on identity federation, prompt and policy layers, retrieval systems, vector stores, memory, tool invocation, software pipelines, API gateways, model providers, data platforms and human approval workflows. An agent can also inherit the permissions of the workload or user identity under which it operates. A system that appears low-impact when viewed component by component may therefore become consequential when those components are composed.

This creates an assurance problem. A component inventory can establish what exists. A control checklist can establish whether expected safeguards are claimed or observed at individual points. A policy can define desired behaviour. None of these views, by itself,

guarantees that the assessor can answer a different set of questions: What can this component reach? Through which identity? Under what authority? Across which boundary? Under what preconditions? Which control would stop, constrain, detect or contain the path? What evidence supports each step? What remains unresolved?

The AI Trust Graph methodology is designed around those questions. It does not assume that risk exists only inside a model, nor that every graph connection is dangerous. It treats material assurance as a systems problem in which the composition of relationships, permissions and dependencies can matter as much as the security posture of individual components [ATG-1][ATG-2].

1.2 From component posture to composed consequence

Consider an enterprise assistant that can retrieve internal documents. A conventional review may verify that the model is approved, the application is registered, authentication is enabled and the document platform has access controls. Those are useful facts. But the consequential question may be whether the assistant's retrieval path applies user-level authorization correctly for every source. If a retriever executes with a broad service entitlement, then a user who cannot directly open a restricted document may still obtain content through the assistant. The material risk emerges from a sequence: user identity -> assistant -> retriever -> inherited source entitlement -> restricted document.

The weakness is not necessarily located in the model. It may be produced by the interaction between identity, retrieval architecture, data permissions and missing validation evidence. That is exactly the kind of relationship-dependent assurance problem a graph representation is intended to make explicit.

1.3 Complement, not replacement

AI Trust Graph is not positioned as a substitute for established AI risk, security or management frameworks. NIST AI RMF 1.0 provides a voluntary framework for managing AI risk, and NIST's Generative AI Profile extends that work for generative-AI risks [1][2]. ISO/IEC 42001:2023 defines requirements for an AI management system, while ISO/IEC 23894:2023 provides guidance for AI risk management [3][4]. MITRE ATLAS organizes adversary tactics and techniques involving AI systems [5]. OWASP's 2026 agentic-security work addresses risks and runtime control for autonomous agents, including the Top 10 for Agentic Applications and the Agent Control Standard [6][7]. The World Economic Forum's 2026 agent playbook also emphasizes explicit authorization profiles, auditability and accountable delegated action [8].

AI Trust Graph addresses a narrower methodological question: how to represent and assess connected trust, authority and exposure relationships, link them to controls and evidence, preserve uncertainty, and produce bounded assurance conclusions. It is therefore intended to interoperate with, and provide evidence to, broader governance, risk and security processes rather than replace them.

1.4 Related work and differentiation

Graph-based security analysis is not new. Attack-graph research has long represented multistep compromise paths and used graph analysis to reason about defensive interventions [9][10]. Likewise, trust graphs, identity graphs, authorization models and delegated-authority controls have established precedents across security and distributed systems. Current agentic-security guidance increasingly focuses on identity, privilege, tool use, authorization and runtime control [6][7][8].

This whitepaper therefore does not claim that graphs, attack paths, trust relationships, evidence grading, maturity models, or delegated-authority governance are individually novel. The proposed contribution of AI Trust Graph is their integration into one governed AI-assurance methodology: a directed, labelled multigraph of assessment objects and conditional relationships; explicit separation of trust from effective authority; evidence-gated path validation; control-breakpoint reasoning; first-class uncertainty states; six-domain maturity and control assessment; a controlled lifecycle; and bounded reporting and decision discipline.

That distinction matters for evaluation. The relevant question is not whether ATG invented graph reasoning, but whether the integrated method is coherent, reproducible, useful and sufficiently differentiated in practice. Those questions require external review, inter-assessor testing and field calibration; this paper does not treat architectural synthesis as empirical validation.

1.5 Assurance must remain bounded

A credible assessment has limits. Discovery may be incomplete. Provider internals may be opaque. Runtime behaviour can change. Evidence may be stale or narrow. A path may be plausible but not sufficiently evidenced. The methodology therefore rejects the idea that every assessment must end in a single definitive number.

Its governing doctrine can be summarized as: scope before collection; evidence before conclusion; conditions before path claims; tests before effectiveness; gates before averages; review before release [ATG-7]. The goal is not to manufacture certainty. It is to make the limits of certainty visible enough that decisions remain accountable.

2. Why graph reasoning

2.1 Why a directed, labelled multigraph

The canonical representation is a directed, labelled multigraph [ATG-2]. Direction matters because authority, invocation, data movement and dependency are not generally symmetric. Labels matter because a connection called "can invoke" has a different assurance meaning from one called "trusts", "reads from", "delegates to" or "controlled by". Multiple edges between the same objects matter because two components may simultaneously have data, identity, trust and control relationships.

This representation allows the methodology to preserve context that is easily lost in an inventory or undifferentiated architecture diagram. A relationship is not merely a line. It is an assertion with scope, conditions, evidence and confidence. A path is not merely reachability in the mathematical sense. It is an ordered explanatory structure whose material steps and preconditions must be supported or explicitly marked unresolved.

2.2 The reasoning chain

The narrative reasoning chain used in this paper is:

Assets -> Relationships -> Authority -> Paths -> Controls -> Evidence -> Decisions

This is not the six-domain assessment model and does not replace the thirteen-phase lifecycle. It is a conceptual reading order for understanding how ATG turns system structure into an assurance conclusion.

Assets establish the objects in scope. Relationships describe how those objects interact. Authority describes the effective or permitted capacity to access, influence or change a target. Paths compose ordered relationships into potential consequences. Controls identify breakpoints that can stop, constrain, detect or contain progression. Evidence establishes what can defensibly be asserted about those objects, relationships, conditions and controls. Decisions record accountable treatment, acceptance, escalation or other disposition.

2.3 Graph locality and systemic consequence

A useful property of graph reasoning is the ability to move between local detail and systemic effect. A weak approval control may be local to one workflow edge, but its consequence can be systemic if that edge sits on many paths to high-impact actions. Conversely, an alarming-looking component may not create a material path if necessary permissions, protocols or conditions are absent.

The methodology therefore includes a strict anti-error rule: a topological connection is not automatically an exploitable or active path. Required permissions, state and preconditions must be evidenced or explicitly preserved as UNKNOWN [ATG-1][ATG-4]. Graph structure creates a hypothesis space; evidence and validation determine which claims can be made within scope.

2.4 Boundaries are first-class

A boundary is not merely a drawing convention. It marks a change in ownership, enforcement, trust assumptions, data handling or assurance responsibility. Provider transitions, account boundaries, privilege boundaries, human-approval points and data-classification transitions can all be material. Treating boundaries as first-class assessment objects makes it possible to ask whether the assumptions on one side remain valid after the system crosses to the other.

This matters in AI ecosystems because a workflow can move rapidly across organizational and technical domains: a user action can reach a hosted model, trigger an agent, invoke a third-party tool and act against an enterprise system. The point of graph reasoning is not to make the picture more complex. It is to make the consequential transitions reviewable.

3. The AI Trust Graph model

3.1 Core objects

The whitepaper uses a compact conceptual vocabulary while leaving the full ontology to Artifact #12. Nodes represent typed assets or assessment objects such as identities, agents, applications, tools, data resources, providers, controls, evidence objects and findings. Edges represent directional relationships such as access, authorization, invocation, retrieval, delegation, dependency, trust, data movement and control coverage. Boundaries capture material changes in ownership, policy or enforcement. Paths join ordered relationships from a start condition to a material target or outcome. Control breakpoints are points where an effective control can materially interrupt progression. Evidence objects support, dispute or qualify assertions.

These objects are intentionally more precise than ordinary architecture notation. Each material relationship should carry enough context to answer: what are the endpoints, what relationship is asserted, in which direction, under which conditions, within which scope, and on what evidence?

3.2 Trust as conditional reliance

ATG does not treat trust as a positive label or reputation score. Canonically, trust is conditional reliance by one entity on another entity, assertion, output, dependency or control for a defined purpose [ATG-12]. A material trust relationship should identify its purpose, basis, scope, owner, transitivity rule if any, expiry, revocation and evidence.

Trust is non-transitive by default. If A relies on B and B relies on C, the methodology does not silently infer that A trusts C for the same purpose. Any such transitivity must be explicit and constrained. This is particularly important in AI supply chains and provider ecosystems, where inherited assumptions can otherwise become invisible.

3.3 Authority as effective capacity

Authority is more than access. It is the effective or permitted capacity of an actor, identity, application, agent, tool or workflow to access, influence or change a target [ATG-12]. A material authority assertion records the acting identity, capability, target, scope, conditions, duration, approval, reversibility, telemetry and revocation.

This model is useful for agentic systems because actionability can be amplified by composition. A model that can only recommend is different from an agent that can invoke a write-capable tool. An agent executing through a privileged service identity is different again. The critical assurance question is therefore not simply "what can the model output?" but "what effective action can the composed system cause, under which identity and controls?"

3.4 Reachability and paths

Reachability may be direct, indirect, chained, inherited, delegated or UNKNOWN [ATG-12]. A path records a start condition, ordered traversal, conditions, boundary crossings, target, controls, evidence and confidence, and any residual path after intervention.

The path is an explanatory object, not just a graph query result. If a consequential step lacks evidence, the assessor must not invent the missing condition. The path remains constrained by UNKNOWN until evidence or authorized testing resolves the question. This discipline prevents graph density from being mistaken for risk certainty.

3.5 Historical integrity

Completed assessment runs are historical records. Later evidence, architectural change or remediation does not rewrite what was true at the time of the prior run. New evidence creates a new or superseding state. This version discipline supports reproducibility and makes trend claims more defensible.

4. Trust, authority and material paths

4.1 Why trust and authority must be separated

Trust and authority interact but are not interchangeable. A system may trust a provider's model output for summarization while granting that provider no authority to modify an enterprise record. A workflow may grant an agent authority to open a ticket while the human operator does not trust the agent to approve a financial transaction. Conflating the two hides the decision boundary.

ATG therefore asks two separate questions. First: what reliance is being accepted, for what purpose and on what basis? Second: what action can actually be taken, against which target, under which identity, conditions and approval model? Only after these questions are answered should the assessor reason about the path that composes them.

4.2 Authority amplification

Authority can be amplified when a downstream relationship increases reach, privilege, scale, impact or autonomy. Several forms are especially important in connected AI systems: identity amplification through inherited credentials; tool amplification when a reasoning component gains access to a powerful action surface; data amplification when retrieval broadens accessible information; workflow amplification when repeated or automated actions compound effect; temporal amplification when standing permissions persist; and trust amplification when one accepted assertion cascades into downstream decisions.

Amplification is not automatically a vulnerability. It is a property that changes the assurance question. Stronger actionability generally requires stronger identity isolation, meaningful approval, telemetry, revocation, resource bounds and recovery capability.

4.3 Path validation

A material path requires evidence for every consequential relationship and condition [ATG-6]. Unsupported conditions remain UNKNOWN and constrain the path state. This requirement is central because graph analysis can otherwise overstate exposure by treating every theoretical route as active.

For example, a graph may show an agent connected to a payment API. That alone does not prove the agent can execute a transaction. Relevant conditions may include authentication, allowed operations, transaction thresholds, human approval, environment, rate limits and runtime policy. The assurance conclusion should reflect what is actually demonstrated.

4.4 Alternate and residual paths

Breaking one path does not necessarily remove exposure. A control breakpoint analysis should consider alternate routes and the residual path that remains after intervention. If a workflow blocks one tool but another tool reaches the same target, the system may still have equivalent effective authority. Likewise, a human approval gate may be nominally present but ineffective if the workflow can bypass it through another integration.

Graph reasoning adds value by making these alternate compositions visible and by showing whether a remediation genuinely cuts the relevant path or merely changes its route.

5. The six assurance domains

The canonical control library contains seventy-two controls: twelve controls in each of six domains [ATG-5]. The whitepaper does not reproduce those controls; it explains how the domains divide the assurance problem.

5.1 D1 - Discovery and AIBOM

Discovery establishes the assessed estate, ownership, dependencies, source coverage and blind spots. An AI Bill of Materials (AIBOM) supports lineage across models, data, identities, tools, runtime components and dependencies. The domain does not assume that automated discovery proves completeness. Coverage and unresolved population remain visible.

5.2 D2 - Trust and Privilege Paths

This domain represents trust relationships, identity and privilege paths, boundaries, provider dependencies, path conditions and graph quality. It is where the methodology asks whether a topological route is actually supported by the permissions, state and evidence required to make it material.

5.3 D3 - Authority Governance

Authority Governance focuses on what actors and machine entities can actually cause: action taxonomy, delegation, impersonation, least authority, approvals, amplification, resource limits, data destination authority, segregation, revocation and recertification. For agentic AI, this domain is the bridge between model behaviour and operational consequence.

5.4 D4 - AI Security Validation

Security Validation converts threat hypotheses into authorized testing. It covers model, prompt, context, retrieval, memory, agent, multi-agent, tool, MCP, supply-chain, runtime and control-breakpoint testing. Testing is governed by rules of engagement and safety; a technically possible test is not automatically authorized [ATG-7].

5.5 D5 - AI Governance and Assurance

This domain connects technical assurance to policy, risk appetite, use-case intake, impact and misuse assessment, jurisdiction and obligations, lifecycle approval, exceptions, provider due diligence, competence and independent assurance. It prevents technical controls from becoming disconnected from decision rights and business accountability.

5.6 D6 - Operational Resilience

Operational Resilience covers telemetry, attribution, detection, incident taxonomy, triage, containment, agent kill or pause mechanisms, credential and delegation revocation, rollback, business recovery, evidence preservation and exercises. It asks not only whether a path can be prevented, but whether the organization can detect, contain and recover when prevention fails.

5.7 The domains are integrated, not six silos

A material issue often crosses domains. A broad service identity may originate as a D3 authority problem, create a D2 privilege path, require D4 validation, depend on D1 inventory accuracy, trigger D5 exception governance and require D6 containment capability. The six-domain profile is therefore intended to show uneven capability without collapsing it into one number.

6. Control breakpoints

6.1 Controls as graph interventions

A control breakpoint is a node, relationship or boundary where an effective control can materially stop, constrain, detect or contain a path [ATG-12]. The concept shifts attention from the existence of controls to their position and effect within a consequential sequence.

A breakpoint may prevent progression, for example by denying an unauthorized tool call. It

may constrain progression through least privilege or transaction limits. It may require meaningful approval. It may detect an anomalous action and trigger containment. It may reduce blast radius through segmentation or isolated identities. Or it may support recovery and forensic reconstruction after an event.

6.2 Design intent is not operating effectiveness

ATG distinguishes control design, implementation and operating effectiveness. A documented approval requirement can support design evidence, but it does not prove that the production workflow enforces the approval every time. A configuration export may demonstrate implementation, but an operating-effectiveness claim requires stronger evidence of actual or representative operation under the relevant conditions [ATG-6].

This distinction is essential for breakpoint reasoning because a path is only constrained to the extent that the breakpoint actually operates. A control drawn on an architecture diagram is not automatically a path cut.

6.3 Independence and concentration

Breakpoints should also be reviewed for independence. Two nominally separate controls may depend on the same identity provider, administrator or policy engine. If that common dependency fails, the graph can reveal correlated control failure. Conversely, a strategically placed independent breakpoint can reduce multiple material paths.

The purpose is not to optimize purely for the largest number of graph edges removed. Remediation must still consider consequence, feasibility, ownership, resilience and the risk of creating alternate routes.

7. Evidence and epistemic discipline

7.1 Evidence is a relationship, not a document count

The canonical Evidence Model states that evidence is a governed relationship between a source and a precisely stated assertion within defined scope, time, conditions and limitations [ATG-6]. This is a fundamental design choice. An assessment should be able to explain what was observed, how it was obtained, what the evidence supports, what it does not support, and who approved the conclusion.

The model separates evidence grade, evidence quality, assertion confidence, coverage and reviewer decision. Combining these dimensions into one score would create false certainty.

7.2 Evidence grades E0-E5

The methodology uses six evidence grades from E0 to E5. At a high level, E0 represents a reviewed no-evidence basis for the specific assertion; E1 represents inference or uncorroborated signal; E2 represents attestation; E3 represents approved documentary evidence; E4 represents corroborated technical evidence; and E5 represents direct technical and representative evidence [ATG-6]. E0 is used only where an E0 evidence basis is explicitly recorded and reviewed; the simple absence of a linked `EvidenceItem` is not automatically an E0 `EvidenceItem`.

The grade describes support, not desirability. High-grade evidence can prove that a control is ineffective. Low-grade evidence can weakly suggest that a control is effective. Evidence grade must therefore never be added to control effectiveness, severity, maturity or risk as

if they were the same quantity.

7.3 Sufficiency is claim-specific

Evidence is sufficient only for a specific conclusion. The Evidence Model establishes claim-specific minimums and additional quality conditions. Design, implementation and operating effectiveness are distinct claims. Evidence sufficient for one does not automatically support the others.

At the frozen baseline, a finalized numeric design component requires claim-specific E3-or-stronger support; implementation requires claim-specific E4-or-stronger technical evidence from the deployed or configured environment; operating effectiveness requires claim-specific E5-quality evidence. A component score of 5 or an adaptive or continuous-assurance claim requires repeated E5-quality evidence across relevant material changes [ATG-6]. Meeting the grade threshold is necessary but not sufficient: relevance, scope, currentness, representativeness, conflict status and reviewer decision still govern.

7.4 Evidence-supported score caps

The Scoring Framework includes an evidence support ceiling. It limits the highest numeric component score the accepted evidence can support; it does not turn evidence quality into effectiveness and does not grant a score merely because a high-grade item exists [ATG-4]. This prevents a weakly supported favourable observation from being expressed with unjustified numeric precision.

7.5 Conflict and provenance

Evidence can support, dispute, qualify, corroborate, derive from, supersede or duplicate another assertion or evidence item. Conflicting evidence remains visible until it is resolved or the conclusion is bounded. Provenance and supersession are retained so that the assessment can be reconstructed later.

This discipline is also the boundary for AI-assisted analysis. Automated extraction, classification or summarization may propose assertions, but model output cannot silently become approved fact. Material facts and high-impact decisions require accountable human review.

8. UNKNOWN and bounded assurance

8.1 UNKNOWN is a first-class state

The canonical result-state model preserves UNKNOWN, Not Assessed, Not Applicable, Not Tested, Inconclusive, Provisional and Final within scope as distinct states [ATG-7][ATG-12]. UNKNOWN means that material evidence is absent, insufficient or materially conflicting.

UNKNOWN is not zero. It is not a weak score. It is not proof of failure. It is not safety. It is not Not Applicable. It is not Not Tested. These distinctions matter because silently collapsing uncertainty into a numeric value can change a decision.

8.2 Why UNKNOWN matters for paths

Suppose a graph shows that an agent can invoke a tool, but the assessor cannot establish whether the production identity has permission to execute a sensitive operation. Encoding that missing condition as zero would make the path appear safer than the evidence justifies.

Encoding it as maximum exposure would be equally unjustified. The correct state is UNKNOWN until evidence or authorized validation resolves the question.

For path sufficiency, every consequential relationship and condition must either be supported or explicitly remain UNKNOWN [ATG-6]. An unresolved material reachability question therefore prevents a final point PEI rather than being encoded as zero merely to complete the arithmetic.

8.3 Bounded assurance

This leads to a broader doctrine: assurance should be no stronger than the evidence and declared scope permit. The methodology therefore prefers a narrower, defensible statement over a broad but weak one. "Final within scope" is not the same as universal truth; it means required review and evidence gates are complete for the declared scope.

Bounded assurance is not a weakness in the methodology. It is a control against false precision. In complex AI ecosystems, the ability to state what remains unknown can be as decision-relevant as the ability to state what has been verified.

9. Assessment lifecycle

The canonical Assessment Methodology defines thirteen controlled phases. Phases may iterate, but required gates cannot be skipped merely because information was available earlier [ATG-7].

1 Initiate. Establish an approved charter and decision purpose. This defines why the assessment exists and who has authority to act on its result.

2 Scope. Establish the versioned boundary, population, period, exclusions and assessment unit. Claims later in the assessment cannot silently exceed this boundary.

3 Discover. Measure the AI-enabled estate using authorized sources and preserve blind spots. Automated discovery does not prove completeness.

4 Model. Construct and review the graph snapshot: objects, relationships, boundaries and relevant context.

5 Evidence. Collect, protect, grade and link evidence to precise assertions. Conflicts, limitations and provenance remain visible.

6 Controls. Determine applicability and assess control design, implementation and operation according to the canonical control library and evidence rules.

7 Paths. Validate material paths, conditions, boundary crossings, controls and residual routes. A graph connection alone does not establish exploitability or active reachability.

8 Maturity. Determine the six-domain maturity profile using cumulative, evidence-gated rules.

9 Scoring. Produce transparent scorecards, coverage measures and eligible path triage values without manufacturing an overall trust score.

10 Findings. Record evidence-linked gaps, control deficiencies, path exposures and remediation objectives with clear condition and consequence.

11 Decisions. Record accountable gates, exceptions, acceptance or other disposition. Management acceptance changes disposition, not the underlying technical result.

12 Report. Release a quality-reviewed decision package with scope, evidence, uncertainty, paths, findings, maturity and limitations.

13 Reassess. Trigger a new or updated run after material change, evidence expiry, remediation or other defined events. Completed prior runs remain historical records.

The lifecycle turns graph analysis into governed assurance. It also separates activities that are often collapsed in informal assessments: discovery from completeness, evidence from conclusion, control design from effectiveness, findings from management disposition, and historical records from current state.

10. Scoring and decision discipline

10.1 No overall trust score

AI Trust Graph intentionally does not publish one overall AI Trust Graph or "trust" score in v1.0 [ATG-4]. The evidence base does not justify reducing trust, authority, security, governance, resilience, uncertainty and maturity into a universal number. A six-domain profile is more transparent because it preserves uneven capability and unresolved gates.

10.2 Maturity is cumulative and non-compensating

The M1-M5 maturity model is rule-based, cumulative and evidence-gated [ATG-3]. Higher capability in one area cannot average away a missing prerequisite or critical gate in another. This protects against a common dashboard failure mode in which many favourable low-impact measures obscure one consequential weakness.

10.3 Control scoring remains evidence-bounded

Control scoring separates design, implementation and operating effectiveness. Critical gates apply before aggregation. Evidence grades and confidence are not added to effectiveness. Coverage retains a visible denominator and unresolved population. Severity and confidence remain separate [ATG-4].

The whitepaper deliberately does not reproduce the full scoring tables. Those remain canonical in Artifact #4.

10.4 Path Exposure Index

For eligible, determinate active paths, the methodology defines the Path Exposure Index for triage:

$$PEI = 4 \times \text{Consequence} + 3 \times \text{Reachability} + 3 \times \text{Authority} + 2 \times \text{Amplification} + 3 \times \text{Control Resistance}$$

The range is 7 to 62 for determinate eligible active paths [ATG-4]. The arithmetic promotes consistent prioritization, but it does not create probability. PEI is not expected loss, certification status or a universal comparison score. The component profile remains the explanation.

The methodology also preserves critical overrides and eligibility rules. A mathematically calculated value must not be used to conceal an invalid path state or an unresolved material condition.

10.5 Decision discipline

A score is an input to judgment, not a substitute for it. A decision should preserve the reasoning chain: scope -> claim -> evidence -> graph context -> control or path state -> finding -> accountable disposition. This lets a reviewer understand why the decision was made and what evidence or change would cause it to be revisited.

11. Worked synthetic example: Enterprise Knowledge Copilot

This section uses the governed synthetic reference case RA-01 from Artifact #10 rather than inventing a new case. The case is fictional and has no relationship to a real environment, vendor, tenant or organization [ATG-10]. Its purpose is calibration and explanation, not empirical validation.

11.1 Decision question and bounded architecture

RA-01 represents an advisory enterprise knowledge copilot grounded in enterprise repositories and user identity. The synthetic decision question is whether the copilot may proceed within the stated conditions. The scope is one bounded production-like use case and directly material dependencies.

Discovery produces usable but explicitly incomplete coverage: four of five approved source classes return usable evidence; five of six material objects have accountable ownership; model, data, identity, tool and runtime components are represented in the AIBOM; and one component is externally controlled or indirectly observed. The resulting conclusion is a usable bounded inventory, not complete-estate assurance.

11.2 Graph, trust and authority

The material path hypothesis is:

User identity -> copilot -> retriever -> inherited broad source entitlement -> restricted document

The effective authority is characterized as read, retrieve, infer and recommend. The case requires stable typed nodes and directed edges with scope, conditions, evidence and confidence. Trust has a stated purpose, basis, owner and revocation. Authority records capability, target, duration, approval and reversibility. The calibration explicitly prohibits adding conventional architecture edges that are not supported by the case evidence.

The key architectural issue is compositional. The user may not have direct entitlement to the restricted document, but the retriever can inherit a broader source entitlement. Whether the path is material depends on the actual authorization behaviour and evidence for denied-access retrieval, not merely on the existence of a connection to the repository.

11.3 Evidence package

The synthetic evidence set intentionally mixes stronger support and a material weakness. Approved architecture or policy provides E3 design support. Configuration or runtime export

provides E4 implementation support. A representative authorized test provides E5 where stated. Owner attestation is E2 and requires corroboration. The weakest item is an E0 representative denied-access retrieval test.

Confidence is assigned per assertion rather than once for the entire case. SUPPORTS, DISPUTES and QUALIFIES relationships remain visible. This means a single high-grade item does not upgrade every claim in the case.

11.4 Calibrated control subset

The reference subset contains one control from each domain: ATG-DIS-005 scores 3 with E3 evidence and Medium confidence; ATG-TRU-009 scores 2 with E4 and Medium confidence; ATG-AUT-003 scores 2 with E4 and Medium confidence; ATG-VAL-006 scores 1 with E5 and Low confidence; ATG-GOV-001 scores 3 with E3 and Medium confidence; and ATG-RES-001 scores 2 with E4 and Medium confidence.

This subset is illustrative and does not replace full applicability analysis. The example also shows why evidence grade is not the same as effectiveness: ATG-VAL-006 has E5 evidence but a low score. Strong evidence can establish that a condition is weak.

11.5 Material path and PEI

The calibrated path has the following PEI components: Consequence 4, Reachability 3, Authority 2, Amplification 2 and Control Resistance 4. Using the canonical formula produces a PEI of 47, in the High band. The interpretation is strictly triage priority; it is not probability or expected loss.

The case remains disciplined about what the number means. PEI does not say that exploitation is 47 percent likely, that expected loss is 47 units, or that the whole system is 47 percent trustworthy. It prioritizes this eligible path relative to the methodology's own component model.

11.6 Uneven maturity is preserved

The six-domain maturity vector is D1 M3, D2 M2, D3 M2, D4 M1, D5 M3 and D6 M2. The values are not averaged into a single maturity number. The vector makes the weak security-validation domain visible even though discovery and governance are further developed.

11.7 Findings and accountable decision

The synthetic findings include an Evidence Gap because the representative denied-access retrieval test is E0, a Control Deficiency because an applicable control objective is not sufficiently effective, and a Path Exposure covering the user-to-restricted-document route.

The calibrated decision is: Conditionally continue bounded use; close source-entitlement and representative retrieval-test gaps before sensitive-source expansion.

This is an important illustration of ATG's decision discipline. The methodology does not need to call the whole system safe or unsafe. It can support a bounded continuation decision while making the evidence gap, path exposure and prerequisite actions explicit.

11.8 Ruthless reviewer question

Artifact #10 attaches a useful calibration challenge: Which conclusion changes if the weakest evidence item is removed, narrowed or contradicted? That question forces the assessor to distinguish conclusions that are structurally robust from conclusions that depend on one fragile evidence item.

12. Reporting and accountable decisions

12.1 The graph is not the final deliverable

The purpose of an assessment is not to produce an impressive network visualization. The graph is an analytical substrate. The report must translate graph context into claims, evidence, findings and decisions without hiding scope or uncertainty.

The canonical Reporting Standard requires an assessment identity, versioned scope, method and limitations, estate and AIBOM view, trust and boundary view, authority view, control assessment, path portfolio, maturity profile, scorecards and coverage, findings, decisions, roadmap, limitations and sign-off [ATG-9]. Executive reporting must disclose critical gates, coverage and residual uncertainty rather than reduce the result to a traffic light.

12.2 Findings remain separate from disposition

A finding records the technical or assurance condition. Management acceptance, exception or treatment records what the organization decides to do about it. Acceptance does not make the underlying condition disappear. This separation preserves technical integrity and allows future reviewers to understand whether risk changed or only its disposition changed.

12.3 Traceability survives to the decision

A defensible decision should be traceable back to the evidence and graph context that support it. This is particularly important for consequential AI because policy statements and high-level risk language can otherwise become disconnected from the actual system path. ATG's reporting discipline is intended to preserve the chain from observed state to accountable action.

13. Limitations and current validation status

13.1 Methodological coherence is not empirical validation

A governed methodology can be internally coherent without having demonstrated that independent assessors will apply it consistently across real organizations. The current artifact stack includes synthetic calibration material and a reproducibility protocol, but the frozen baseline explicitly records inter-assessor reproducibility validation as a pending external gate.

13.2 Synthetic cases are not field proof

Artifact #10 contains synthetic reference cases designed for calibration, adversarial checks and reasoning consistency. They must not be represented as observed facts about real vendors or organizations. A synthetic worked example can demonstrate how rules interact; it cannot prove predictive validity, business impact or external effectiveness.

13.3 Scoring has known limits

The Scoring Framework states that ordinal judgments do not become objective probabilities

merely because arithmetic is applied. Weight choices require transparency and calibration. Cross-organization benchmarking is unsafe unless scope, profile, evidence, formula version and review quality are equivalent. UNKNOWN dependencies must remain UNKNOWN rather than being forced into the scoring model [ATG-4].

13.4 Evidence also has limits

The Evidence Model cannot guarantee source truth, complete discovery, legal admissibility, statistical representativeness, absence of deception or permanent currency [ATG-6]. Provider opacity, rapid change, sampling limitations and human judgment remain real constraints. The methodology's response is not to deny these limits but to disclose them and narrow claims accordingly.

13.5 No guarantee of safety, compliance or certification

AI Trust Graph assessments do not guarantee future system behaviour, complete risk elimination or legal compliance. The governance model prohibits scores, maturity levels, conformance statements or future certificates from implying guaranteed safety or trustworthiness [ATG-11]. Version 1.0 defines certification readiness architecture; it does not launch an accredited certification scheme.

13.6 Frozen validation status for this paper

As of methodology bundle 1.0-rc.4, the pending external release gates are: independent methodology or architecture review; independent AI-security review; inter-assessor reproducibility study; employer/IP/confidentiality review; and legal approval of the licence/trademark position. If those gates change after this paper is published, the historical paper should remain unchanged and a later version should update the status rather than silently rewriting the old record.

13.7 Non-normative validation agenda

The next credibility step is empirical rather than rhetorical. Without changing canonical semantics, independent evaluation should test whether separate assessors reach materially consistent conclusions from the same evidence; whether path and breakpoint reasoning remains stable under realistic architectural change; whether PEI weights and bands are useful after field calibration and sensitivity analysis; and whether the resulting reports improve decision traceability without encouraging false precision [ATG-4][ATG-10][ATG-M].

This agenda is intentionally non-normative. It describes evidence that would strengthen confidence in the methodology; it does not create new conformance requirements or imply that the pending validation has already occurred.

14. Governance and methodology evolution

14.1 Scope-based authority

The methodology does not use a simplistic one-dimensional precedence order. The Methodology Manifest resolves authority by scope: the Manifesto governs public purpose and non-negotiable commitments; the Core Conceptual Model governs conceptual semantics; the Ontology formalizes those semantics; specialist artifacts govern maturity, scoring, controls, evidence, execution, reporting and governance within their declared authority [ATG-M].

If a conflict is detected, the affected conclusion or claim is paused, evidence and version state are preserved, and the issue is resolved through governance. The whitepaper has no authority to resolve such a conflict by reinterpretation.

14.2 Controlled evolution

Canonical concepts, control IDs, evidence grades, maturity semantics and scoring logic should change only through governed methodology change. Published versions and completed assessments remain immutable historical records and are superseded rather than overwritten. This principle protects the methodology from silent semantic drift and allows users to reconstruct which rules were applied to a particular assessment.

14.3 Tool independence

The methodology can be executed with documents, spreadsheets, graph stores or compatible platforms. Tool output remains proposed until evidence, scope, method and review support acceptance. A commercial implementation may automate execution but cannot become a hidden source of canonical meaning.

Artifact #13, the Reference Graph Schema and Illustrative Query Library, is a Phase 2 non-normative companion. It carries no conformance weight at this baseline and cannot redefine the twelve core artifacts. L4 Tool-compatible conformance is explicitly unavailable until approved normative machine-readable schemas and conformance test vectors exist [ATG-M].

14.4 Publication boundary

This whitepaper is intentionally a front door. It synthesizes the reasoning model but does not replicate the seventy-two controls, complete M1-M5 capability matrices, full E0-E5 tables, ontology registry, scoring tables, assessor field guidance, reporting templates or implementation query library. Readers who need operational rules should use the pinned canonical artifact stack.

Conclusion

AI assurance becomes harder when the relevant unit is no longer an isolated model but a connected system of identities, agents, tools, data, providers, workflows and human decisions. In such systems, consequential exposure can emerge from composition: a trust assumption inherited across a provider boundary, a delegated identity that increases actionability, a retrieval path that crosses authorization expectations, or a control that exists in design but does not reliably interrupt the path in operation.

AI Trust Graph proposes a structured way to make those relationships explicit. It represents assets and relationships as a directed, labelled multigraph; distinguishes conditional trust from effective authority; treats paths as evidenced explanatory structures; locates control breakpoints; separates evidence strength from effectiveness; preserves UNKNOWN rather than scoring it away; and links technical conclusions to accountable decisions through a controlled assessment lifecycle.

Its contribution is not a universal trust number. It is a discipline for asking what can be concluded, why it can be concluded, what path or control the conclusion concerns, and where the evidence requires the answer to remain bounded.

The methodology remains a public-release candidate at the frozen baseline and has important

external validation gates still open. Those limitations should remain visible. If AI Trust Graph develops further, its credibility will depend not only on richer artifacts or tooling, but on independent challenge, reproducibility, field calibration, transparent governance and continued resistance to false precision.

Better assurance does not require pretending that every uncertainty can be scored away. It requires knowing what can be concluded, why it can be concluded, and where the evidence requires the answer to remain UNKNOWN.

Appendix A. Whitepaper-to-canonical traceability matrix

Whitepaper subject	Canonical authority	Semantic guardrail
Publication status / authority | METHODOLOGY_MANIFEST.md; #1; #11 | Non-normative paper; canonical artifacts prevail; frozen validation status
Assurance problem | #1; #2 | System-level reasoning; composition and path emphasis; complement existing standards
Graph reasoning | #2; #12 | Directed labelled multigraph; edges are conditional assertions; topology is not exploitability
Trust | #2; #12 | Conditional reliance; purpose/basis/scope/owner/revocation/evidence; non-transitive by default
Authority | #2; #12 | Effective/permitted capacity; identity/capability/target/scope/conditions/approval/revocation
Paths | #2; #6; #12 | Ordered explanatory structure; evidence for consequential conditions; residual and alternate paths
Six domains | #3; #5 | Exact canonical domain names; 12 controls per domain; do not reproduce full catalog
Control breakpoints | #2; #5; #12 | Stop/constrain/detect/contain; design is not operating effectiveness
Evidence | #6; #4 | E0-E5; grade is support not truth; sufficiency is claim-specific; evidence cap is a ceiling not an entitlement
UNKNOWN | #4; #6; #7; #9; #11; #12 | Never zero/pass/fail/NA; distinct from Not Tested and Inconclusive
Lifecycle | #7 | Exact 13 phases: Initiate, Scope, Discover, Model, Evidence, Controls, Paths, Maturity, Scoring, Findings, Decisions, Report, Reassess
Maturity | #3 | M1-M5 cumulative, evidence-gated and non-compensating; no averaging
PEI | #4 | Exact formula and 7-62 eligible determinate range; triage only, not probability or expected loss
Worked example | #10 | RA-01 only; fictional/synthetic; retain calibrated path, maturity vector, PEI and bounded decision
Reporting | #9 | No one-number trust score; disclose coverage, uncertainty, critical gates and evidence
Governance | #11; Manifest | Scope-based authority; historical integrity; tool independence; #13 non-normative
ExposureGraph boundary | #1; #2; #7; #11 | Product and proprietary implementation excluded

References

[1] Tabassi, E. (2023). Artificial Intelligence Risk Management Framework (AI RMF 1.0). NIST AI 100-1. DOI: 10.6028/NIST.AI.100-1.
[2] Autio, C., Schwartz, R., Dunietz, J., Jain, S., Stanley, M., Tabassi, E., Hall, P., & Roberts, K. (2024). Artificial Intelligence Risk Management Framework: Generative Artificial Intelligence Profile. NIST AI 600-1. DOI: 10.6028/NIST.AI.600-1.
[3] ISO/IEC 42001:2023. Information technology - Artificial intelligence - Management

system. International Organization for Standardization.

[4] ISO/IEC 23894:2023. Information technology - Artificial intelligence - Guidance on risk management. International Organization for Standardization.

[5] MITRE ATLAS. Adversarial Threat Landscape for AI Systems. <https://atlas.mitre.org/>

[6] OWASP GenAI Security Project. OWASP Top 10 for Agentic Applications for 2026.

<https://genai.owasp.org/resource/owasp-top-10-for-agentic-applications-for-2026/>

[7] OWASP GenAI Security Project. Agent Control Standard (ACS). 1 September 2026.

<https://genai.owasp.org/resource/agent-control-standard-ac/>

[8] World Economic Forum. (2026). AI Agents in Action: A Playbook for Trusted Adoption, Authorization and Scaling. 26 May 2026.

[9] Swiler, L. P., Phillips, C., Ellis, D., & Chakerian, S. (1998). A graph-based network-vulnerability analysis system. Sandia National Laboratories. DOI: 10.2172/573291.

[10] Sheyner, O., Haines, J., Jha, S., Lippmann, R., & Wing, J. M. (2002). Automated Generation and Analysis of Attack Graphs. Proceedings of the IEEE Symposium on Security and Privacy, 254-265. DOI: 10.1109/SECPR1.2002.1004377.

[ATG-M] AI Trust Graph Methodology Manifest, bundle 1.0-rc.4, snapshot 2026-09-26, manifest blob 82c401ad27d31ddc0078e58dd99f38ac0b71a7d9.

[ATG-1] AI Trust Graph Artifact #1 - Manifesto, v1.0.

[ATG-2] AI Trust Graph Artifact #2 - Core Conceptual Model, v3.0.0.

[ATG-3] AI Trust Graph Artifact #3 - Maturity Model, v1.0.

[ATG-4] AI Trust Graph Artifact #4 - Scoring Framework, v3.0.0.

[ATG-5] AI Trust Graph Artifact #5 - Master Control Library, v2.0.0.

[ATG-6] AI Trust Graph Artifact #6 - Evidence Model, v2.0.0.

[ATG-7] AI Trust Graph Artifact #7 - Assessment Methodology, v1.1.0.

[ATG-9] AI Trust Graph Artifact #9 - Reporting Standard, v1.1.0.

[ATG-10] AI Trust Graph Artifact #10 - Reference Assessment Repository, v2.0.0.

[ATG-11] AI Trust Graph Artifact #11 - Governance & Certification Model, v1.0.

[ATG-12] AI Trust Graph Artifact #12 - Ontology Specification, v3.0.0.

[ATG-13] AI Trust Graph Artifact #13 - Reference Graph Schema and Illustrative Query Library, v0.4.0, Phase 2 non-normative companion.